

Data Security Issues Arising From Integration of Wireless Access Into Healthcare Networks

John C. Frenzel^{1,2}

The versatility of having Ethernet speed connectivity without wires is rapidly driving adoption of wireless data networking by end users across all types of industry. Designed to be easy to configure and work among diverse platforms, wireless brings online data to mobile users. This functionality is particularly useful in modern clinical medicine. Wireless presents operators of networks containing or transmitting sensitive and confidential data with several new types of security vulnerabilities, and potentially opens previously protected core network resources to outside attack. Herein, we review the types of vulnerabilities, the tools necessary to exploit them, and strategies to thwart a successful attack.

KEY WORDS: wireless networks; security; medical data; 802.11b; hacker.

INTRODUCTION

Wireless mobile connectivity for voice and data is one of the modern era's most rapidly adopted technologies. Commercial cellular telephones were first introduced to consumers in the United States in 1982. The International Telecommunication Union estimated that at the end of 2001 there were 1.045 billion fixed lines, compared to nearly 1 billion mobile phones worldwide. Forrester Research forecast that in 2003 growing U.S. wireless revenue, at \$66.6 billion, would overtake the declining total of long distance and local revenue, seen at \$17.5 billion and \$40.6 billion, respectively. By 2006, Strategy Analytics estimates there will be close to 1.9 Billion global cellular subscribers. In some parts of the world cellular has supplanted landline phones for personal communication.¹ The enormous growth in cellular subscribers demonstrates the demand for mobile voice connectivity.

A similar trend is beginning in the wireless data transmission arena. High-speed wireless connectivity standards have been in existence for several years. These

¹The University of Texas M. D. Anderson Cancer Center, Houston, Texas.

²To whom correspondence should be addressed at The University of Texas M. D. Anderson Cancer Center, 1515 Holcombe Blvd., Box 42, Houston, Texas 77030-4009; e-mail: johnfrenzel@seinarsystems.com.

include Hiper LAN, the 802.11 series, and Bluetooth (IEEE 802.15.1). Recent market consolidation has begun to limit the number of choices competing for the attention of the end user. Widespread adoption of the 802.11b standard in the United States and the introduction of inexpensive chipsets, have made enterprise wireless connectivity a viable alternative to wired infrastructure from both a price and performance standpoint.

The last several years have also shown a disturbing trend. As wired networks have grown, so have the malicious threats to their security and operation. Viruses, worms, and denial of service attacks are well known and commonly encountered. As high bandwidth wireless networks grow and become a more visible means of data transfer, this malicious threat is likely to follow. It can reasonably be expected that network attack, bandwidth theft, information resource corruption along with denial of service will occur across wireless links.

The amount of personal medical data stored on networked computers is increasing rapidly. The federal government, in trying to leverage the efficiencies of electronic data processing and common electronic transaction standards, created the Health Insurance Portability and Access Act (HIPAA) regulations. With a federal mandate to move health data online, the Department of Health and Human Services codified strict new standards for personal health information security and privacy.² Compliance with these regulations using current off the shelf wireless hardware is difficult. This document will explore the infrastructure, technology, and policies necessary to close common security gaps in wireless networks. It is also critical for individuals involved with hospital networks to be able to assess their vulnerabilities. Tools freely available to assess wireless networks will also be examined.

WIRELESS DATA INFRASTRUCTURE AND PROTOCOLS

As with any new consumer technology, wireless networking has evolved in many directions creating multiple incompatible standards and products. Wide area networking via cellular phone was one of the earliest systems. Cell phones from Motorola were designed in the mid nineties with specific features to enable easy connection to analog modems for data transport. The cellular industry has continued to expand their data product offerings with Short Messaging Service (SMS) and Cellular Digital Packet Data (CDPD). These products offer many advantages to mobile users, including wide geographic reach, transparent link creation and tear down, no base station cost, and high system uptime. Drawbacks include cost, proprietary signaling systems, and low bit rate. SMS is primarily a text based messaging system that delivers 160 character messages to network subscribers. The service is aimed more at the text pager market, enabling cell phone users to send text-based communications. CDPD is a higher speed IP packet based technology operating at 19.2 Kbps. Competitors in this space include Metricom with a higher speed (28.8–128 Kbps) service. Metricom is available in only 13 cities and further service expansion is questionable. Neither of these options really provides a single useable solution available nationwide for healthcare data users.

At the other end of wireless connectivity is Bluetooth. It is designed to connect nodes no further than 10 m apart and was conceived as the basis of a personal area network. Bluetooth delivers high-speed connections (10 Mbps) with very low power due to the limited design range. Current standards locate it in the 2400 MHz Industrial Scientific and Medical (ISM) band. Applications envisioned for Bluetooth include ad hoc replacement for wired components, i.e., keyboard to PC, or wireless headset to cell phone. Bluetooth is a well-designed standard with built in stacks to handle diverse type of connections including data, voice, and fax. It is structured as a decentralized network with nodes joining or leaving the network space with little overhead. Bluetooth will be destined to join together devices, rather than join roaming users to a wired LANs, given the limited network range and the high fixed costs required to allow seamless connectivity in building size spaces.

Enterprise wide wireless networking requires a solution between the extremes of cellular and Bluetooth. Requirements include connectivity across multiple rooms from a single base station to keep fixed costs low, and megabit class data rates to support modern graphically rich interfaces with low latency connections. Manufacturers began to develop products to fill this need. Specifications of 5–10 Mbps over 100 m became a common goal. Within this space several groups developed products including Intel's HomeRF, Ericsson's Hiper LAN 1, and the IEEE's 802.11. A common theme for these technologies was to connect mobile users and devices to preexisting wired, typically Ethernet, networks. Base stations or access points act as the gateway between the wireless and wired realms. Access points commonly perform the function of a translational bridge, converting packets from the wired, generally Ethernet 802.3 structure to the format dictated by the wireless protocol. Access points are wireless protocol specific and the decision to purchase a particular access point determines the protocol and technology users will be forced to adopt. Taking into account range, user density and signal strength, network designers place access points in strategic locations to cover the area to be served. Care must also be taken in the design phase to understand the total RF footprint of the installation, as leakage of signal into public areas potentially opens the network to attack by outsiders.

Manufacturers of first generation equipment chose the 2400 MHz ISM band for transport. This section of spectrum is set aside for unlicensed use. The band is 100 MHz wide (2400–2500 MHz) and can handle multiple high data rate channels. This band, however, is exceptionally noisy as it is the output frequency of industrial and domestic microwave ovens, cordless telephones, and other common wireless devices. Communication equipment using this section of spectrum must accept any interference and are given no protection from noise. This band, however, holds several important advantages. It allows unlicensed use, so manufacturers of equipment did not need to buy spectrum rights for users. Spectrum rights are commonly granted or sold by governments on a regional basis and are extraordinarily expensive. By using "free" spectral space, service cost was dramatically reduced and barriers to competition lowered. Also, the ISM band is allocated worldwide for unlicensed use, so manufacturers had the incentive to create and market products globally.

As market share and the drive to interoperability pruned the number of commercial offerings, the 802.11b standard emerged as the dominant 10 Mb technology. The U.S. Institute of Electrical and Electronics Engineers (IEEE) originally drafted

the 802.11 standards.³ The whole 802 family forms the basis of modern networking protocols with 802.3 describing Ethernet, 802.5 covering Token Ring, and 802.2 detailing the Data link layer of the IP stack. 802.11b is an extension of Ethernet protocols to wireless. 802.11b networks, like wired networks, use a shared media. To manage media contention and recover from collision, these networks implement Carrier Sense Multiple Access/Collision Avoidance (CSMA/CA). Since 802.11b is a derivative of Ethernet, it is also susceptible to many of the same attacks. Other groups set out to create entirely new protocols specifically designed for wireless networking. The advantage of adapting a preexisting and proven set of protocols to the new medium of wireless gave the 802.11 group a jump start on the competition and a significant first mover advantage over all other competitors.

Second generation devices designed to deliver more bandwidth to users have been developed and are approaching widespread deployment. These devices are created primarily to deliver a 2–4 times increased transfer rate over 802.11b. Due to the attendant increase in bandwidth necessary to support these higher rates, designers moved to the 5000 MHz ISM band (5150–5825 MHz). These higher frequencies contain the necessary bandwidth to accommodate 54 Mbps data rates over multiple channels. By increasing the carrier frequency users are faced with several tradeoffs in performance. As frequency increases, signal energy tends to propagate less for a given power output. Consequently, devices at these frequencies require higher power output for comparable range. Energy at higher frequencies tends to travel in a line of sight pattern, and is more attenuated by walls or floors. Both these factors tend to limit coverage and increase the number of access points necessary to provide uniform connectivity across a given space. In battery-powered devices, the increased energy consumption could dramatically curtail use. These penalties must be considered against the increased link bandwidth.

Two groups predominate in this market and are split along geopolitical boundaries. The IEEE group based in the United States proposed a standard that extends and enhances 802.11b called 802.11a. They once again chose to adapt a proven protocol to a new environment. This updated standard employs eight independent channels with a capacity of 54 Mbps. Again it is based in the Ethernet CSMA/CA protocol for media contention. It is not connection oriented and does not support explicit Quality of Service (QoS) guarantees. Access points are simple gateways and translators, and do little to manage communication flow. A European Consortium headed by Ericsson created the Hiper LAN 2 protocol. This standard is closer in design to Asynchronous Transfer Mode (ATM) networking protocols. It relies on central control of channel usage based on a Time Division Multiple Access (TDMA) scheme. Each node is assigned specific timeslots for transmission of data by the access point. With predetermined timeslot media access, time sensitive data can be delivered with higher level of temporal certainty. The protocol formalizes these provisions for QoS so that voice or video can be delivered with minimal packet loss. Hiper LAN 2 also incorporates adaptive power management, so that output power can be adjusted to deliver the minimum signal strength necessary to allow robust communication. 802.11a and Hyper LAN 2 are incompatible with each other at a fundamental level. These devices will never interoperate. As in the 10 Mbps networking arena, market factors will ultimately decide which standard will dominate. Considering the capital

expense in creating a connected environment, most users will continue to implement 802.11b until a clear winner emerges.

AVENUES OF ATTACK

In the last few years, security has become an important issue for all members connected to the global network. Attacks aimed at compromising resources, stealing data, and theft of bandwidth are launched daily at users across the Internet. Wireless Internet connectivity due to its local nature requires attacker and victim to be in close physical proximity. Commonly cited risk statistics show 55% of all network attacks originate from employees within an organization.⁽⁴⁾ The largest group of potential attackers already resides locally. Wireless access points potentially open new portals to the interior of a network.

Finding, gaining access to, and compromising a wireless network require specialized tools, knowledge, and equipment. The relative newness of the technology makes specialized tools scarce as compared with the number available to penetrate and compromise wired networks. This is rapidly changing. In the past year many more capable and flexible software packages are appearing on the Internet. As these tools become robust, streamlined, and support more off the shelf hardware, the number of individuals capable of mastering them to compromise organizations increases. Many managers and network professionals also underestimate the state of the art in regard to threats posed by local talent.

802.11b based networks are now the standard wireless data implementation in the United States. Because of this popularity, tools are being specifically developed to facilitate penetration of these sites. 802.11b was derived from 802.2 and 802.3 (the fundamental protocols underlying common wired Ethernet connections). Many tools developed to penetrate wired networks need only modest enhancements or extensions to work with 802.11b packets. Fundamentally, 802.11b security rests on three legs, channel selection, Service Set Identifier (SSID), and Wired Equivalent Privacy (WEP). For users to connect to a wireless access point, the client's card must be set to the correct channel and configured for the right SSID. WEP is an encryption layer that uses shared keys. It implements link layer encryption using the RC4 stream cipher,⁽⁵⁾ but the use of WEP is completely optional. To be successful, attackers need to acquire all three pieces of information so as to be able to gain access to the gateway or the data stream and move to the next step of network compromise.

Wireless network configuration takes place at the access points. When these devices are initially configured, system administrators select a fixed channel number from 1 to 11. The channel corresponds to a carrier frequency for users of that network access point. For redundancy and full coverage, multiple access points can be configured for operation on the same channel. To help load balance the network and provide users better throughput, administrators can deploy multiple access points overlapping in an area configured on different channels. Administrators also must choose a SSID. The Service Set ID allows multiple networks configured with different SSIDs to coexist on the same channel. This is done so that overlapping networks

need only be assigned distinct Service Set IDs to operate correctly. Owners of adjacent networks do not need to coordinate frequency selections. The SSID is a name or identifier assigned to the network. A single network comprised of multiple access points distributed geographically throughout a location, would have all the access points configured with the same SSID.

The 802.11b standard requires that access point broadcast beacon packets containing the SSID and other information at regular intervals. Several software packages exist that configure the wireless card to continually step through the channels listening for and recording beacon packets. They essentially use the card as a scanner to detect beacon transmissions and identify access points. Beacon packets also contain flag data indicating whether WEP is enabled. Successful capture of this information gives the attacker the network SSID along with channel number. This is the basic information necessary to escalate the attack. One of the best packages available on the Internet is Net Stumbler.⁽⁶⁾ It is an integrated offering that automatically records beacon packets and optionally interfaces with GPS receivers to map the coordinates of stations heard. It is designed for users to map the location of access points and record essential access data. With this sort of information automatically gathered while driving, the user can then perform offline analysis later, and prepare for specifically for further attacks.

WEP is an optional link layer encryption. It uses the RC4 stream cipher with 40 to 128 bit length keys. Keys are initially generated by the system administrator and then loaded into the access points as well as all wireless clients. This is the shared key. Key management and distribution are largely manual processes. Due to this overhead, WEP is commonly not used. If WEP is in use, the attacker must recover the shared key before being able to escalate the attack. Due to the overhead involved in key change, key lives are usually extremely long. Because the key is shared, all members of the network generate traffic using the same key. When the 802.11b standard was written, the authors failed to specify how the initialization vectors in the key space were chosen. Card manufacturers implementing the standard as written have commonly created firmware that upon power up, reset the initialization vector to zero. Using the same starting point caused frequent key stream reuse. Reuse of the key stream makes recovery of the shared key certain given enough packet traffic to analyze.⁷ Researchers at Rice University created software to monitor packets of WEP enabled networks, and using cryptanalysis were able to recover the shared keys following capture of between 100 and 1000 MB of network traffic.⁽⁸⁾ This software is now publicly available on the Internet in packages such as AirSnort.⁽⁹⁾

As with any network security plan, physical security is one of the most critical pieces. With wired networks, physical security approximates building security. Sign in desks, ID badges, and locked doors provided a controlled environment that makes direct physical attack more risky. Network compromise takes time and a physically secure environment limits the attacker. Wireless loses this protection. The media, RF signals, are not well contained by buildings or walls, and propagate in unpredictable ways. Site surveys to determine network footprint take a backseat to providing users high signal strength and wide coverage. Due to the short wavelengths used in all data LAN applications, powerful compact high gain antennas can be constructed

with commonly available materials that yield good signal strength at distance.¹⁰ Off the shelf antennas are inexpensive and easily obtained. With a high gain antenna, attackers need not be even physically on site to capture beacon signals, and high volumes of encrypted traffic. They can carry out their attack from locations hundreds and even thousands of feet away.

Attacks can be divided into active and passive. Passive attacks consist of traffic analysis and packet logging. For this type of attack, the intruder need not transmit. Having the SSID, channel number, and shared key (if necessary), the attacker records all packet transmissions across the wireless link. Several software packages exist to place client wireless network cards into “Promiscuous Mode.” Promiscuous mode is a state in which the network adapter passes all traffic on the media to the upper layers of the network stack. Whether intended for that adapter address or not, all packets crossing the link can be captured, archived, or immediately examined by application programs. This activity can continue for as long as necessary, limited only by patience and disk space. At a later time, packet-display software such as TCPDump⁽¹¹⁾ can be used to view the captured data. More advanced tools such as Ethereal⁽¹²⁾ or TCPTrace⁽¹³⁾ can be used for packet analysis. Aside from raw data, this sort of analysis can yield unencrypted passwords for telnet, pop3, and other sessions. As a strategy, passive attacks are useful to gain an understanding of traffic patterns and data flows along with hard compromises of user names and passwords. It can also provide a wealth of information to advance attacks based on social engineering.

Active attacks involve tools and strategies aimed at becoming a member of the network and compromising users and resources attached to it. The access point acts as a gateway into the wired segments of a LAN. An attacker can leverage information found from the passive stage to enter resources and access services using legitimate users identities. This allows the attacker to gain privileges and escalate the attack on machines located in the wired segments of the network. Commonly these resources are protected from Internet attack behind a firewall located between the LAN and the Internet. Being screened from the Internet and physically secure, it is oftentimes considered that these machines and users operate in a more trusted and thus more open environment. Wireless attackers benefit from these attitudes, and find poorly configured and extremely vulnerable resources.

To this point the object of interest being attacked was the network behind the access point. However, this is not always the goal. Many businesses buy high-speed connections to the Internet to support day-to-day operations. Using high-speed wireless cards and the above techniques, a nonemployee can freeloader on the network and steal bandwidth. As more high bandwidth applications come into use, this will become a more significant problem. Additionally, all activities of the freeloading individual will appear to originate from the host network. If the interloper is downloading pirated software or copyrighted music, investigators will ultimately be led back to the host network. Using a wireless access point as a gateway to the Internet requires no user authentication beyond channel selection and SSID as stated above. A freeloading user will leave little trace in system logs, and will be extremely difficult to track given the possibility that they may never have even set foot on the premises.

SECURITY APPROACHES

Data security touches many aspects of an enterprise from physical structure to purchasing, policy, and procedure. All these elements impact data security, but no piece by itself is the total solution. Information technology and enterprise networking is a dynamic environment that is subject to periodic disruption with the introduction of new applications. Wireless is extremely disruptive on many levels and security solutions addressing wireless must also be sought across the continuum of threats (Table I).

When first faced with the need to secure wireless access points, administrators look to use tools at hand to restrict access. Media Access Control (MAC) address filtering and Dynamic Host Configuration Protocol (DHCP) are oftentimes used first. These approaches provide little in the way of gateway security and do nothing to deter passive attacks. The DHCP was never designed for access control and can easily be circumvented. One strategy an attacker can employ would be to capture IP addresses passively and then configure their client card to use a valid address in the same address block. The user simply configures the access card manually with IP address, netmask and gateway information, effectively bypassing DHCP. MAC address filtering is not much more effective. Network administrators configure switches to block frames from all but specified MAC addresses. To circumvent this, attackers need only obtain the MAC address of a valid user and then configure their wireless card to “spoof” this address.¹⁴ Simple traffic capture will yield valid MAC addresses. This is a trivial level of security that comes with a big price to organizations. Collecting MAC addresses and tracking them over time in a large enterprise is labor intensive and ultimately of little additional value. It inconveniences users more than attackers, and wastes administrators’ time with updates and changes to the MAC database.

As a stopgap measure, network designers can move all access points into a separate “public internet” zone. This is a good first strategy in that it recognizes the reality of the security situation. Wireless users are segregated from the rest of the network. Placing access points on a separate VLAN or network segment helps to insulate wired users from uncontrolled wireless threats. Generally this special segment is placed behind a firewall and Access Control Lists (ACL) or filters are created so that connections can be strictly controlled and monitored. ACLs are usually static lists and are rather inflexible. If a site chooses to make use of filters, interior access must be limited to only certain machines and services. These machines must be

Table I. Summary of Security Strategies with Tradeoffs and Enterprise Costs

	Management complexity and cost	Host network security	Data link security	Number of supported clients	Ease of scalability
DCHP	Low	Low	None	High	Medium
MAC	Medium	Low	None	High	Low
Public Internet	Low	High	None	High	High
WEP	Low	Medium	Medium	High	Medium
RADIUS	Medium	High	None	Medium	High
VPN	High	High	High	Low	Medium
SSL	Medium	High	High	High	High

hardened as any asset exposed to a public network. For small numbers of users and small numbers of services, this can work well, however, it scales poorly and fails when the number of requested services or connections grows. Use of intrusion detection devices on this segment is also wise. These monitors can act as an early warning system to alert network administrators to a potential threat.

The wireless standards committees, device manufacturers, and third party vendors have created many effective packages and upper layer protocols to compensate for the limitations of 802.11b. One approach is to consider the wireless user similar to a dialup user and require authentication from a firewall located directly behind the wireless gateway. This is similar to the structure of authentication taking place at an access server connected to a bank of dial in modems. Systems using Remote Authentication Dial In User Service (RADIUS) have been deployed for many years in the dial up environment. The RADIUS protocol, infrastructure, and management tools were created to facilitate central user administration. The system is robust and scales well supporting thousands of accounts. User information can be modified continuously with very low overhead, so adding or dropping an individual is quickly manifest in modification of access rights. Adapting this technology for wireless use leverages preexisting tools and experience of systems administrators. One technique is to allow wireless users to establish Ethernet connections using Point-to-Point Protocol over the wireless link (PPPoE). The user authenticates to the PPP server and if successful, the PPP session is created. RADIUS uses a shared secret to validate user logins. Because the secret is only used in authentication transactions, very little traffic is generated with it. Key recovery based on analysis of encrypted packets requires large volumes of traffic. This approach fails due to the small volume of authentication traffic generated. RADIUS support is nearly omnipresent, so integration of wireless users into this preexisting fabric can be quickly accomplished.

Modeling wireless users as dial up clients is a valid approach for authentication and access control. This causes wireless policy to mirror dial up policy and simplifies the task of integrating wireless users into the preexisting policy structure. To this extent, it is a valid approach. RADIUS protects the network from unauthorized access. Authentication at the gateway becomes a significant barrier for outside threats attempting to penetrate deeper into the network. It fails to address user security and security of data in transit. Packets continue to be sent unencrypted and open to inspection. For individuals collecting packets and performing traffic analysis and data recovery, RADIUS has no effect. This can only be solved with packet level or transaction level encryption.

WEP was designed to be a method for encrypting the link layer. Due to poor design and implementation in the 802.11b standard, it provides little additional security. The RC4 stream cipher it is based on, however, has been found to be very robust. Several vendors have created proprietary schemes such as Cisco who created Lightweight Extensible Authentication Protocol (LEAP). These solutions attempt to address the poor implementation of RC4 in WEP, while continuing to support the 802.11b standard in all other ways. Cisco creates a proprietary structure for central key management that includes dynamic key creation and automated key distribution. They also implement simplified user authentication and management via an integrated RADIUS server. This package addresses many of the weaknesses inherent

in 802.11b. Key management is centralized and transparent so that key changes can occur frequently and without user intervention. This makes traffic analysis nearly impossible due to the limited key lifetimes. If key compromise were to occur, the period of network vulnerability would be extremely short. Use of RADIUS to authenticate users locks down access points, and WEP encryption properly implemented masks user data contained in packets. These improvements make Cisco's version of 802.11b a much more robust and secure protocol. As with any proprietary solution, users are locked in to a single vendor and do not have the benefit of market forces in helping to exert competitive pricing pressure. The Cisco solution is in process with the IEEE to become a recognized part of the 802.11 standard.¹⁵ This path, however, is long and will take many months before a unified open standard is finally adopted.

Security can also be implemented at the session level. Virtual Private Networking (VPN) tunnels can be established that can move packets across the wireless link securely encrypted. The tunnel will carry all traffic generated by a user and due to the robust nature of the encryption create an extremely secure end-to-end connection. VPN technology is commonly used on wired networks to bring remote users seamlessly through a firewall and into a secured network. Users experience modestly decreased packet throughput and some increased computational overhead. In wireless networks these burdens take on greater importance with bandwidth-limited channels and compute cycle limited handheld clients. VPN is also a very vendor specific application at this time. For wireless access to be supported on a range of devices from portable computers to handheld devices, VPN becomes difficult to implement. Two large vendors, Microsoft and Cisco do have implementations supporting a range of heterogeneous clients.

VPN enables remote users to participate in a network as equals as compared to local wired users. Many times, this sort of broad access is unnecessary and users need only a more limited function set. Some commonly used Internet protocols incorporate robust session level security features. The HTTPS protocol underlying secure web-based transactions is one. If the user's interface can be browser based, then these sessions can be secured with Secure Socket Layer (SSL) connections. Encryption of the data occurs at the browser and data is decrypted on the destination web server. This creates a secure tunnel for these communications using strong cryptographic, including Triple DES, Twofish or the Advanced Encryption Standard (AES). Web clients and servers also offer a range of robust user authorization and authentication mechanisms. System designers can choose from simple cookie-based techniques or more conventional user ID and password interactions. Many browsers support digital certificates for client authentication, providing a very high level of authenticity.

Using a web browser on the client side of the connection has several major advantages. The web browsers are supported across a broad range of clients. Configuration is quick and most users can create a secure connection using the default settings. Since the encryption is occurring above ISO layer 3, client network configuration such as default route and IP address assignment can be handled with an unmodified DHCP server. Because of the simplicity of configuration, user support costs can be significantly less. This represents a distinct economic advantage over a VPN solution. Most system's administrators have experience in building and

configuring secure web servers. Leveraging this mature technology offers stability, rapid time to deployment, and reasonable cost structure. For smaller organizations with limited budgets and little networking support, the web server gateway offers a good compromise of cost, security, and flexibility.

The burden for security in this type of configuration is almost entirely dependent on the configuration of the gateway web server. This resource constitutes a single point of failure for all enterprise wireless users. If wireless access is considered a critical service, then a failover configuration must be deployed. Web server security is under constant assessment and challenge by hackers. These systems need to be patched and updated regularly as new vulnerabilities are discovered. Implementations such as Apache tend to be robust, scalable, and have a low cost of ownership.¹⁶ Use of Java applications via a web browser can extend the functionality of the interface to support e-mail, instant messaging, and telnet. Use of a Web-based interface creates the opportunity to introduce a rich variety of applications and services to users. This approach builds on the existing trend to extend the web interface to multiple applications and services. As an organization creates web-based external or private intranet portal applications, it becomes trivial to offer these services to wireless users in a secure and authorized manner. Access to web-based resources on the Internet can be granted via a proxy server. Because the connection is carried over SSL, to the proxy, the data remains strongly encrypted independent of the ultimate web destination. An SSL server used in this manner would need to be hardened and secured as any resource exposed to the unfiltered Internet. The server interface attached to the wireless access point would have to be locked down and provide only a minimal set of open ports. Using a web gateway simplifies wireless user management by creating a single point of authentication and resource access control.

NETWORK PROCEDURE AND POLICY

With wireless products widely available, physical security must assume a more proactive role. Low entry level pricing and simple configuration encourage individual users to easily set up privately owned access points on the enterprise network. These “Rogue” gateways can lead to compromise to interior trusted networks. Audits of the physical space with wireless “sniffers” looking for and tracing beacon signals is one of the best approaches to police this threat, but can be very labor intensive and time-consuming given a large installation. Port scanning sections of network and fingerprinting attached devices is an effective, low cost auditing tactic. To the network, access points are seen as hubs or bridges, and exist only at ISO layer one. Most access points, however, are equipped with in band management facilities and these ports can be detected with port scans. Using stack fingerprinting of suspicious network nodes can rapidly pare down the number of potential targets. Tracing the physical location and ownership on a large LAN is a challenge. As a countermeasure, technically adept employees can install a second networking card in a desktop workstation and attach the wireless access point. The legitimate workstation is then configured to perform port address translation on packets from the access point. In this case, network scans would never reveal the presence of the access point because it is masquerading behind

the workstation. Enterprise networking and security policy must specifically address this circumstance. To truly assure that no rogue access points are deployed, physical audits using wireless sniffers are mandatory.

Following deployment of a wireless network, systems administrators need to create a map the RF footprint. This is useful from a security standpoint in defining areas of excess signal leakage, and from a user satisfaction standpoint to identify areas of low signal strength. Optimizing the footprint for comprehensive interior coverage while limiting external leakage is difficult and time consuming. By creating a signal strength map, however, the enterprise begins to define the physical profile of potential network vulnerability. Quickly resurveying the perimeter of this map on a regular basis can help identify changes due to antenna placement and construction. It can also serve as a reference for problem solving when faced with user coverage issues.

Enterprise networks are large complex designs built to deliver stability and throughput in a cost-effective manner. Networking infrastructure has a design life-time commonly exceeding 5 years. Threat profiles and network risks will change dramatically during this timeframe. Designing network infrastructure to mitigate known security threats is prudent. But one must realize that as technology and associated threats evolve, the basic design of the installed network will remain relatively static due to high costs of reconfiguration and the impact reconfiguration will have on enterprise applications and overall stability. The existing firewall and network configurations are essentially static, so to counter new threats, active defenses must be deployed. Intrusion detection systems (IDS) are special monitors connected across the network that continually search for evidence of attack and system compromise. As threats change and new vulnerabilities emerge, updating and reconfiguring these detection systems is a fast, simple, and cost-effective way to meet the challenge. Because IDS only monitor network activity, changes, upgrades, and redeployment of these systems do not necessarily require network downtime or introduce networking instability. This element becomes the flexible part of threat response.

CONCLUSIONS

Future implementations of wireless hardware and protocols will deliver higher bandwidth and greater security. Currently 802.11a equipment is coming to market, and Bluetooth is beginning to be found in commercial products. No technology is perfect, and determined attackers will find gaps and holes in any network. Because of the enormous installed base and cost-effectiveness, 802.11b will be in use carrying sensitive information through the remainder of the decade. Hospital administrators, network designers, and end users must be aware of the risks posed with wireless data links. Protection of health data is the responsibility of all involved with healthcare delivery. Wireless data links offer continuous campus wide high-speed connectivity to mobile users. In healthcare, providers can have access to the on-line information resources that they need to deliver rapid, low cost, and high quality medical care. Informed providers armed with the most recent information can make decisions and plan patient stays to maximize benefit and reduce wasted hospitalized days. An

integrated clinical information system can drive down healthcare costs while having a positive impact on patient satisfaction and quality of care.

REFERENCES

1. McMillan, A., *China Cell-Phone Use Hits 140 million* [On-line]. Retrieved December 21, 2001, from <http://asia.cnn.com/2001/BUSINESS/asia/12/21/china.cellphone>
2. Security and Electronic Signature Standards, 63 Fed. Reg. 43242, 1998 (to be codified at 45 CFR Part 42).
3. L. M. S. C. of the IEEE Computer Society, Wireless LAN medium access control (MAC) and physical layer (PHY) specifications. *IEEE Standard 802.11*, 1999 edn., 1999.
4. Vatis, M., Statement for the record of Michael A. Vatis, Director, National Infrastructure Protection Center Federal Bureau of Investigation, Before the Senate Judiciary Committee, Criminal Justice Oversight Subcommittee and House Judiciary Committee, Crime Subcommittee Cybercrime, Washington, DC, 2000.
5. Rivest, R. L., The RC4 Encryption Algorithm. RSA Data Security, Inc., March 12, 1992. (Proprietary).
6. NetStumbler [Computer Software], 2002. Available: <http://www.netstumbler.com/>
7. Borisov, N., Goldberg, I., Wagner, D., Intercepting mobile communications: The insecurity of 802.11. *Paper Presented at the Meeting of the Seventh Annual International Conference on Mobile Computing and Networking*, July 2001, Rome, Italy.
8. Stubblefield, A., Ioannidis, J., Rubin, A. (eds.), *Using the Fluhrer, Mantin, and Shamir Attack to Break WEP* (TD-4ZCPZZ), AT&T Labs Technical Report, Homedale, NJ, August 2001.
9. Air Snort [Computer Software], 2002. Available: <http://airsnort.sourceforge.net/>
10. Homebuilt High gain Wireless Antennas [Wireless Hardware], 2002, Available: <http://home.attbi.com/~joony4/>
11. TCP Dump [Computer Software], 2002. Available: <http://www.tcpdump.org/>
12. Ethereal [Computer Software], 2002. Available: <http://www.ethereal.com/>
13. TCP Trace [Computer Software], (2002). Available: <http://jarok.cs.ohiou.edu/software/tcptrace/index.html>
14. Whalen, S., *An Introduction to Arp Spoofing* [On-line]. Retrieved April 2001, from, http://packetstorm.widexs.nl/papers/protocols/intro_to_arp_spoofing.pdf
15. Meredith, G. (ed.), Securing the wireless LAN: Cisco plugs holes in the 802.11 standard. *Cisco Corporation Packet Magazine*, San Francisco, CA, July 2001.
16. Vijaian, J., Microsoft stands by IIS despite Gartner recommendation. *Computerworld* [On-line]. Retrieved September 26, 2001, from http://www.computerworld.com/storyba/0,4125,NAV47_STO64226.00.html

Copyright of Journal of Medical Systems is the property of Kluwer Academic Publishing / Academic and its content may not be copied or emailed to multiple sites or posted to a listserv without the copyright holder's express written permission. However, users may print, download, or email articles for individual use.